PAYGO FINANCIAL TECHNOLOGIES LTD

GDPR DATA Mapping & SOC 2 Readiness Assessment

Organized by 10Alytics Consulting

Submitted by: Pod Group - Orion

Christiana Appiah
Concord Ekwonna
Emmanuel Sola Majekodunmi
Olawale Badamosi
Ogochukwu Francisca Kelvin-Nwaigwe
Oreoluwa Akintayo Soares

GRC-C26-08-EU-007

Submitted to:
Oladipo Taiwo Olamide
10Alytics Consulting

Date
October 30th, 2026

1. Executive summary

PayGo Financial Technologies Ltd. is a Dublin-based fintech company with 120 employees, providing digital payment services across Ireland and other EU countries. Its operations rely on cloud infrastructure and third-party service providers.

This assessment evaluates PayGo's personal data processing practices against GDPR requirements and its readiness for a SOC 2 examination. The GDPR review covers seven processing activities, while the proposed SOC 2 scope focuses on Security, Availability and Confidentiality.

Our findings identified incomplete processing records, privacy notice disclosures, retention documentation, deletion verification, and third-party processing arrangements. For SOC 2, we identified weaknesses and evidence gaps in access management, MFA, security monitoring, incident response, change management, backup and recovery, and vendor management.

The assessment was limited to the information and evidence made available for review. Certain GDPR obligations and the effectiveness of some security controls could not be fully verified. PayGo has also not undergone a previous SOC 2 examination and lacks a central evidence register. These evidence limitations were not automatically treated as compliance failures.

High-Priority Recommendations

We recommend prioritizing access governance and MFA verification; security monitoring, incident response and backup restoration testing; stronger third-party risk management; and improved GDPR data governance, particularly processing records, privacy notices, retention and deletion practices. PayGo should also strengthen change approval evidence and establish a central SOC 2 evidence register to support ongoing compliance monitoring and audit readiness.

2. Business and Assessment Scope

2.1. Organization/Business Context

PayGo Financial Technologies Ltd. provides digital payment services to individuals and small businesses across Ireland and other EU countries. Its operations involve processing customer registration details, identity verification information, payment transactions, customer support records, employee information and security logs.

These activities are supported by PayGo's web and mobile applications, payment platform, internal systems and external service providers. This processing environment forms the basis of our GDPR assessment and proposed SOC 2 readiness review.

2.2 GDPR assessment scope

Our GDPR assessment reviews PayGo's personal data processing activities, documented privacy practices and available evidence to identify compliance gaps and areas requiring further verification.

The assessment covers seven processing activities: customer registration, identity verification, payment processing, customer support, employee administration, security monitoring and card payments.

The assessment will cover the following areas:

- **Personal data inventory and mapping:** Identify the categories of personal data processed, data subjects, processing purposes, systems, recipients and data flows.
- **Lawfulness, fairness and transparency:** Review lawful bases for processing, privacy notices and how processing activities are communicated to individuals.
- **Data protection principles:** Assess purpose limitation, data minimisation, accuracy, retention periods and secure deletion practices.
- **Records and responsibilities:** Review records of processing activities (RoPA), data protection roles and third-party processor arrangements.
- **Security and breach management:** Assess access controls, MFA, security monitoring, incident response, backup and recovery, and personal data breach procedures.
- **Individual rights and international transfers:** Review data subject rights procedures, processing locations and applicable international transfer safeguards.

The assessment will distinguish between confirmed gaps and areas where evidence is insufficient. Findings will be based on the information provided in the PayGo case study and will not constitute a formal GDPR compliance certification or legal opinion.

2.3. Proposed SOC 2 Scope

The SOC 2 readiness assessment will focus on PayGo's digital payment platform, supporting infrastructure, relevant internal processes and third-party services. The assessment will evaluate the design and available evidence of controls against three selected Trust Services Categories: **Security, Availability and Confidentiality**.

Trust Services Category	Scope of Assessment	Key Controls to Review
Security	Protection of the payment platform and supporting systems against unauthorized access and security threats.	Access management, MFA, security monitoring, incident response, change management, and third-party risk management.
Availability	Reliable access to the payment platform in line with service commitments.	Backup and recovery, restoration testing, system monitoring, and recovery objectives.

Confidentiality	Protection of information designated as confidential against unauthorized access, use or disclosure.	Access restrictions, information handling, system permissions, and third-party safeguards.

The assessment will identify control weaknesses, evidence gaps and areas requiring improvement. A central evidence register is proposed to support control documentation, ownership and future SOC 2 readiness activities.

Scope limitation: This is a preliminary readiness assessment based on the PayGo case study. It does not constitute a formal SOC 2 examination or independent assurance report.

2.4. Systems Identified in Scenario

The PayGo case study identifies several systems and environments supporting its payment services and business operations. The following systems will be considered for the GDPR and SOC 2 readiness assessments, subject to confirmation of their relevance and boundaries.

System/Environment	Business Function	GDPR assessment relevance	SOC 2 Assessment relevance
Digital payment platform	Provide digital payment service	Personal data collection, processing, storage and deletion.	Security, Availability and Confidentiality controls
Cloud infrastructure	Supports platform operations	Data storage, processing locations and international transfers	Infrastructure security, access controls, availability and recovery
Customer support system	Supports customer enquiries.	Customer information, access permissions and retention.	User access controls and periodic access reviews.
Central logging platform	Supports security monitoring	Personal data within logs and retention practices.	Security monitoring, alert reviews and log protection.
Payment processing environment	Supports third-party payment processing.	Data sharing, processor responsibilities and transfers	Third party security, confidentiality and availability dependencies.
Identity verification service	Supports identity verification	Identity data, processing locations and retention	Third part secruity assurance and access controls
Payroll environment	Supports employee payroll.	Employee personal data and retention.	Confidentiality and access controls, where in scope.
Email environment	Supports business communications.	Personal data in communications and retention.	Security and confidentiality controls, where in scope.
Backup and recovery environment	Supports backup and retention	Personal data retention and deletion within backups.	Recovery procedures and restoration testing.
Change management processes and records	Document system changes and deployments.	Changes affecting personal data and privacy safeguards.	Change approvals testing and deployment controls
Access management processes and records	Govern user access and permissions.	Protection against unauthorised access to personal data	Role-based access and periodic access reviews.

Scope Note: The case study does not provide a complete asset inventory, architecture diagram or verified data-flow diagram. Therefore, the systems and processes listed are subject to confirmation and should not be treated as a verified inventory of all PayGo systems.

2.5. Third-Party Providers

PayGo maintains a vendor register and signed agreements with six categories of external providers supporting its business operations. The assessment will review their data protection responsibilities, security arrangements and available assurance evidence.

Third-party Provider	Business Function	GDPR Assessment Considerations	SOC 2 Assessment Considerations
Cloud hosting provider	Provides supporting cloud infrastructure.	Processing locations, contractual terms, data protection roles and international transfers.	infrastructure security, availability, and provider assurance.
Payment processing provider	Processes payments through PayGo's platform.	Personal data sharing, processor roles and transfer arrangements.	Payment security, service availability, and provider risk assessments.
Identity verification provider	Supports customer identity verification	identity data, processing locations and retention.	Security assurance and protection of identity information.
Customer support provider	Supports customer service operations.	Access to customer information, retention and disclosure.	Access restrictions, monitoring and provider security.
Payroll provider	Processes employee payroll/	Employee data, processing roles and retention.	Confidentiality and third-party secruity safeguards, where relevant.
Email provider	Supports business communications.	Personal data in emails, processing locations and transfers.	Email secruity and confidentiality safeguards, where relevant.

The assessment will also consider the completeness of vendor risk assessments, ongoing monitoring and contractual data protection arrangements. Signed agreements alone do not establish that all required safeguards are in place or operating effectively.

2.6. Scope Limitations and Unresolved Questions

This assessment is based solely on the information provided in the PayGo case study. A complete system inventory, architecture and data-flow diagrams, processing records, contractual arrangements and supporting operational evidence were not available for independent verification. Consequently, the assessment cannot fully confirm PayGo's GDPR compliance or the design and operating effectiveness of its SOC 2 controls.

Further verification is required regarding personal data processing activities, lawful bases, retention practices, international transfers, third-party responsibilities, access controls, security monitoring, incident response, backup recovery and change management. Findings will distinguish confirmed weaknesses from evidence gaps, and recommendations will identify the additional documentation or testing required.

3. GDPR data mapping report

The following data inventory identifies PayGo's personal data processing activities based on the information provided in the case study. Where specific systems, data recipients or retention periods have not been identified, these are recorded as **"To be confirmed"** rather than assumed.

3.1 DATA INVENTORY

PROCESSING ACTIVITY	DATA CATEGORIES	DATA SUBJECTS	PURPOSE	SYSTEM/RECIPIENT	RETENTION	INFORMATION NOT SPECIFIED
1.Customer Registration	Customer account information: Full name, email address, phone number, residential address and date of birth.	Customers	Customer account registration.	PayGo web and mobile applications.	While the account is active & for 5 years after closure.	Lawful basis, external recipients, processing/storage location and retention justification
2. Identity verification	Identity verification records: Name, date of birth, address, identity document details, verification result.	Customers	Customer identity verification.	External identity verification provider.	5 years after account closure.	Lawful basis, specific verification system, provider role, processing location, applicable transfer arrangements and retention justification.
3. Payment processing	Transaction records: Transaction reference, amount, currency, date, status, payer and recipient account identifiers.	Customers involved in payment transactions; specific categories not stated.	Payment processing and transaction recording.	PayGo payment platform and database.	7 years.	Lawful basis, external recipients, processing/storage location and retention justification.
4. Customer support	Customer support tickets: Customer name, contact details, ticket description, screenshots or attachments	Customers	Handling customer support requests.	Customer support ticketing system.	3 years after ticket closure.	Lawful basis, external recipients, processing/storage location and retention justification.
5. Employee administration	Employee records: Name, contact details, job title,	Employees	Employee administration.	Human Resources system.	6 years after employment ends.	Lawful basis, external recipients, processing/storage location and

	department, payroll details.					retention justification.
6. Security monitoring	Security logs: User account identifier, login time, IP address, authentication result, relevant system events.	System users; specific categories not stated.	To monitor system activities, identify potential security threats and support accountability.	Central logging platform.	12 months.	Specific data-subject categories, lawful basis, external recipients, processing/storage location and retention justification.
7. Card payments	Card payment information: Payment token, card brand, last four digits of card number, transaction authorisation result.	Cardholders; not expressly identified in the scenario.	Card payment processing.	External payment processor.	Not separately specified.	Specific data subjects, lawful basis, retention period, processing location and applicable transfer arrangements.

3.1. 1 Key data inventory gaps

The following gaps must be addressed before PayGo's GDPR data inventory can be considered complete and reliable.

Gap	Information Required	Recommended Evidence
System inventory	Identify applications, databases and cloud services processing personal data.	Asset register, system inventory, architecture diagrams
Data categories	Confirm the personal data collected and processed for each activity.	Data dictionaries, collection forms, database schemas
Data subjects	Identify all categories of individuals whose data is processed.	Business process records, HR and onboarding documentation
Processing purposes and lawful bases	Document the purpose and applicable lawful basis for each activity.	RoPA, lawful basis assessments, privacy notices
External recipients	Identify third parties receiving personal data and their responsibilities.	Vendor register, contracts, data processing agreements
Retention and deletion	Confirm retention periods and secure deletion arrangements.	Retention schedule, deletion procedures and logs
International transfers	Identify transfers or access outside the relevant jurisdiction and applicable safeguards.	Data-flow diagrams, hosting locations, transfer assessments
Security and access	Confirm access permissions, approvals, reviews and revocation procedures.	Access matrices, access review records, MFA configurations
Data subject rights	Verify how privacy requests are received, tracked and completed.	Privacy request procedures, request register and case records
Accountability	Identify responsible owners for each processing activity.	RoPA, assigned process owners, governance documentation

Assessment note: These are information and evidence gaps identified from the case study. They do not automatically establish GDPR non-compliance. PayGo must provide the relevant documentation for verification.

3.2 Written Data Flow Descriptions

The table below outlines the potential movement of personal data between PayGo's internal systems and third-party service providers, based on the case study. As complete data-flow diagrams and system integration records were not provided, the flows are preliminary and require verification.

PROCESSING ACTIVITY	DATA SOURCE	SYSTEM/RECIPIENT	USE/MOVEMENT DESCRIBED BY SCENERIO	STORAGE/RETENTION	DELETION PRACTICE /EVIDENCE GAP
1. Customer registration	**Customers** providing their registration details.	PayGo web and mobile applications	Customer information is entered into PayGo's web and mobile applications for account registration. Further movement of the data is not described.	Customer account information is retained while the account is active and for five years after closure. Specific storage location is not stated.	Deletion testing for this activity is not confirmed. Onward sharing and deletion procedures require verification.
2. Identity verification	**Customer**-provided identity information	External identity verification provider	Identity information is used for verification involving an external provider. The exact collection method and onward movement of data are not specified	Identity verification records are retained for five years after account closure. Specific storage location not stated.	Deletion has not been tested across all systems and external providers. The deletion method and testing coverage for identity verification records are not specified.
3. Payment processing	Payment transactions initiated by platform users; the exact origin of individual transaction data fields is not specified	PayGo payment platform and database	Transaction information is processed through PayGo's payment platform and database to facilitate payments. Further data movement or onward sharing is not described.	Transaction records are retained for seven years. The specific storage location is not stated.	Deletion procedures for transaction records are not specified. The scenario identifies incomplete deletion testing across systems and external providers; whether payment transaction records are covered requires confirmation.

4. Customer support	Customers (for screenshots and attachments submitted by customers); source of other details not explicitly specified.	Customer support ticketing system. An external customer support provider is identified	Support information is recorded in the ticketing system to handle customer requests.	Customer support tickets are retained for three years after ticket closure. Specific storage location not stated.	Deletion has not been tested across all systems and external providers. The deletion method and testing coverage for customer support records are not specified.
5. Employee administration	Employees (likely source of personal details); origin of HR and payroll information not specified.	Human Resources (HR) system. An external payroll provider is identified, but specific data transfers are not described.	Employee personal and payroll information is processed through the HR system to manage employee records, job roles, departmental information and payroll administration. The specific collection methods and any onward sharing with the external payroll provider are not described	Employee records are retained for six years after employment ends. Specific storage location is not stated.	Deletion has not been tested across all systems and external providers. The deletion procedure and testing coverage for employee records are not specified.
6. Security monitoring	System-generated login, authentication and security event records (inferred). Specific originating systems are not identified	Central logging platform	Login, authentication and system event data are processed through the central logging platform to monitor system security and identify potential security threats. Specific collection methods and onward sharing are not described.	Security logs are retained for 12 months. Specific storage location is not stated.	Deletion has not been tested across all systems and external providers. The deletion procedure and testing coverage for security logs are not spec
7. Card payments	Card payment information originating from cardholders and transaction processing activities	External payment processor.	Card payment information is handled by an external payment processor to complete card transactions. PayGo does not store full card numbers or card verification codes in its application database. Further data movement is not specified	A specific retention period for card payment records is not provided. The storage location of the listed card payment data is not specified.	Processor-specific deletion evidence is not established. Retention arrangements, data sharing and deletion procedures require verification.

3.2.2 Data-Flow Verification Requirements

To complete the GDPR data-flow assessment, PayGo must verify where personal data is collected, how it moves between internal systems and third-party providers, and where it is stored or transferred. Supporting evidence should include data-flow diagrams, system integration records, vendor agreements, storage configurations and deletion procedures. Relevant business, IT and data protection owners should validate the accuracy of these flows.

4.0 GDPR Gap Assessment

4.1 PayGo Financial Technologies Ltd. GDPR Gap Assessment.

This assessment evaluates PayGo's personal data processing practices against the relevant GDPR requirements using the information provided in the case study. It examines key areas including lawfulness, transparency, data protection principles, records of processing activities, data subject rights, security of personal data, processor relationships, breach procedures, and international data transfers.

Assessment Approach: Findings and assessment statuses are based on the available scenario evidence. Confirmed gaps reflect deficiencies expressly identified in the case study, while evidence gaps indicate areas where insufficient information is available to verify compliance. The absence of supporting evidence is not automatically treated as confirmation of GDPR non-compliance.

REQUIREMENT	SCENERIO EVIDENCE	FINDING/STATUS	POTENTIAL RISK	RECOMMENDED ACTION	FURTHER EVIDENCE NEEDED
1. Lawfulness, fairness and transparency - Article 5(1)(a), Articles 12–14	PayGo's privacy notice does not clearly identify every category of recipient or explain all applicable retention periods. The scenario does not establish whether processing is otherwise lawful and fair.	**Confirmed gap:** Privacy notice disclosures are incomplete. Lawfulness and fairness require further verification.	Individuals may not fully understand how their personal data is shared and retained, resulting in transparency and compliance risks.	Review and update the privacy notice to include applicable recipient categories and retention information. Verify that disclosures reflect PayGo's actual processing activities.	Current privacy notice, processing disclosures and evidence of how information is communicated to individuals.
2. Lawful basis for processing - Article 6	The scenario identifies seven processing	**Evidence gap:** There is insufficient	Personal data could be processed	Identify and document the appropriate lawful	Lawful basis register, supporting justifications and

	activities but does not specify the lawful basis for each activity.	information to verify that an appropriate lawful basis has been identified for each processing activity.	without a valid lawful basis, exposing PayGo to regulatory and reputational risks.	basis for each processing activity and verify its supporting justification.	relevant processing documentation.
3. Purpose limitation - Article 5(1)(b)	The scenario identifies processing activities and related systems but does not provide complete documentation of processing purposes or any further use of the data.	**Evidence gap**: Compliance with purpose limitation cannot be fully verified from the available information.	Personal data could be used for purposes incompatible with those for which it was originally collected.	Document the specific purposes of each processing activity and verify that any further processing is compatible with those purposes or otherwise permitted.	Processing purpose records, privacy disclosures and documentation of any secondary uses.
4. Data minimisation - Article 5(1)(c)	The scenario lists personal data categories processed across seven activities but does not explain whether each category is necessary for its stated purpose.	**Evidence gap:** There is insufficient evidence to determine whether PayGo collects and processes only the personal data necessary for each activity.	Excessive collection may increase the likelihood and impact of unauthorised disclosure or misuse.	Review the personal data categories collected for each activity and assess their necessity against the documented processing purpose.	Data collection requirements, field-level inventories and documented necessity assessments.
5. Accuracy - Article 5(1)(d)	The scenario identifies personal data processed but does not describe procedures for verifying, updating or correcting inaccurate information.	**Evidence gap**: The effectiveness of data accuracy controls cannot be established.	Inaccurate customer or employee information could lead to processing errors and privacy-related complaints.	Verify existing data accuracy procedures, including validation, updates and correction mechanisms, and address any identified deficiencies.	Data validation procedures, correction workflows and relevant operational records.
6. Storage limitation - Article 5(1)(e)	PayGo has a documented retention schedule. However, it has not documented the justification for every retention period, and deletion has not been tested across all systems and external providers.	**Confirmed gap**: Retention justifications and deletion assurance are incomplete. The scenario does not establish that any particular retention period is unlawful.	Personal data may be retained longer than necessary or remain in systems after the intended retention period.	Document the justification for each retention period and test deletion across relevant systems and external providers.	Retention justifications, deletion procedures, deletion logs and provider deletion-test results.
7. Records of Processing	The scenario expressly states that PayGo's	**Confirmed gap:** PayGo's RoPA is incomplete,	Incomplete processing records may	Complete the RoPA for applicable processing activities	Updated RoPA, processing inventory and

Activities - Article 30	records of processing activities are incomplete.	limiting visibility and accountability over personal data processing.	result in unidentified processing activities and difficulty demonstrating GDPR accountability.	and establish a process for reviewing and updating the records.	evidence of record reviews.
8. Data protection roles and processor relationships - Article 28	PayGo maintains a vendor register and signed agreements with its external providers. However, provider records do not consistently identify data protection roles, processing locations, applicable transfer arrangements or recent security risk assessments. Risk assessments and ongoing monitoring are incomplete for some providers.	**Confirmed gap:** Provider documentation and oversight are incomplete. Compliance of the signed agreements with Article 28 remains unverified.	Unclear responsibilities and inadequate provider oversight may increase the risk of inappropriate processing, data exposure and contractual noncompliance.	Clarify and document controller/processor roles, review relevant agreements against Article 28, and complete outstanding provider risk assessments and monitoring.	Vendor agreements, controller/processor role assessments, processing-location records, vendor risk assessments and monitoring reports.
9. Security of personal data - Article 32	PayGo has information security policies. However, some permissions are not mapped to approved job roles; access reviews are missing for customer support and central logging; MFA coverage is undocumented; critical alert review timeliness is unverified; incident response has not been tested in twelve months; and backup restoration testing is not evidenced.	**Confirmed gap:** Access governance and security assurance deficiencies are expressly identified. The effectiveness of several other controls remains unverified.	Unauthorised access, personal data exposure, delayed incident detection and inadequate recovery from security incidents.	Complete permission mapping and access reviews, verify MFA coverage and alert monitoring, and conduct documented incident response and backup restoration tests.	Access matrices, access review records, MFA configuration evidence, alert review logs, incident test reports and backup restoration results.

10. Data subject rights - Articles 12 and 15–22	PayGo processes customer and employee personal data, but the scenario does not describe arrangements for receiving, verifying, tracking or responding to data subject requests.	**Evidence gap:** Compliance with applicable data subject rights and request-handling requirements cannot be verified.	Delayed or incomplete responses may result in complaints, regulatory scrutiny and harm to individuals' rights.	Verify and document procedures for handling data subject requests, including identity verification, response deadlines and coordination with external providers.	Data subject request procedures, request logs, response records and relevant provider arrangements.
11. Personal data breach procedures - Articles 33–34	PayGo has an incident response policy, but its procedures have not been tested during the past twelve months. The scenario does not describe GDPR-specific breach notification and communication arrangements.	**Evidence gap:** Compliance with GDPR breach notification and communication requirements cannot be verified. The confirmed incident-testing deficiency is addressed under Article 32.	Delayed breach assessment missed notification deadlines or failure to communicate qualifying high-risk breaches to affected individuals.	Review and test breach assessment, escalation, notification and communication procedures, including applicable reporting timelines.	Breach response procedures, notification decision criteria, incident records, escalation workflows and test results.
12. International transfers of personal data - Articles 44–49	PayGo uses external providers, but provider records do not consistently identify processing locations or applicable international transfer arrangements.	**Evidence gap**: It cannot be established whether restricted international transfers occur or whether appropriate safeguards are in place where required.	Personal data could be transferred outside the EEA without appropriate safeguards.	Identify provider processing locations, determine whether restricted transfers occur and verify the applicable transfer mechanisms and safeguards.	Provider location records, data transfer mapping, relevant transfer agreements and supporting safeguard assessments.

The evidence register identifies documentation and verification requirements across the seven control areas assessed in Section 5.2. Although PayGo maintains relevant security policies, vendor records and operational procedures, the available evidence does not fully demonstrate consistent control implementation and operation.

The principal evidence gaps concern access permissions and periodic reviews, MFA coverage, timely security alert reviews, incident response testing, change approval and testing records, backup restoration, and third-party risk oversight.

PayGo should obtain and review the outstanding evidence, address confirmed deficiencies and establish a central evidence register to support traceability, control evaluation and preparation for a future SOC 2 examination. These findings will inform the integrated gap analysis and remediation plan in Section 6.

4.1.1 Assessment status summary

The following assessment statuses distinguish identified control weaknesses from areas where further evidence or clarification is required.

Assessment Status	Meaning
Gap identified	The case study explicitly identifies a control weakness that requires corrective action.
Evidence required	Available information is insufficient to verify whether the GDPR requirement is being met.
To be confirmed	Further information is needed to determine whether the requirement applies or whether the relevant process or control exists.

4.2 Overall conclusion

The GDPR gap assessment identifies confirmed weaknesses in transparency, retention and deletion assurance, records of processing activities, security of personal data, and third-party provider oversight. These findings highlight areas requiring corrective action to strengthen PayGo's data protection practices and accountability.

Further evidence is required to verify compliance in other areas, including lawful basis, purpose limitation, data minimisation, accuracy, data subject rights, personal data breach notification, and international transfers.

PayGo should prioritise confirmed weaknesses, assign responsible owners and remediation deadlines, and retain evidence of corrective actions. Findings requiring further verification should be reassessed once supporting documentation is obtained.

This assessment is preliminary and does not constitute a formal determination of GDPR compliance.

5. PART B - SOC 2 READINESS ASSESSMENT

5.1 PayGo Financial Technologies Ltd. Selected SOC 2 Trust Services Categories and Criteria

The following table focuses on the three selected Trust Services Categories: Security, Availability and Confidentiality. It identifies why each category and criterion is relevant, the

supporting evidence or limitations described in the PayGo case study, and the findings requiring further assessment.

5.1.1 Security

This table below assesses PayGo's readiness against the nine SOC 2 Security Common Criteria (CC1–CC9), distinguishing weaknesses described in the case study from areas requiring further evidence.

Category / Criterion	Why It Is Relevant	Scenario Evidence	Finding or Limitation
CC1 – Control Environment	Management accountability, governance and oversight of security controls.	Weaknesses identified in access management, monitoring, incident response and change management.	Governance structure, approved policies, control ownership and management oversight require evidence.
CC2 – Communication and Information	Security responsibilities and requirements must be communicated.	Evidence gaps and inconsistent control documentation are described.	Verify policy communication, staff acknowledgements and assigned responsibilities.
CC3 – Risk Assessment	Identify, evaluate and manage risks affecting PayGo's objectives.	The case study does not establish a complete risk register or formal assessment process.	Verify risk methodology, risk ratings, treatment plans and accountable risk owners.
CC4 – Monitoring Activities	Monitor whether controls are functioning effectively.	Access reviews are missing for two systems; security alert review evidence is inadequate.	Control monitoring weaknesses are identified. Verify testing, exceptions and management review.
CC5 – Control Activities	Implement procedures to mitigate identified risks.	Access management weaknesses and inconsistent documentation of change approvals/testing.	Strengthen or verify documented procedures and evidence of consistent operation.
CC6 – Logical and Physical Access Controls	Restrict access to authorised users based on business need.	Permissions are not fully mapped to approved roles; two systems lack access reviews; MFA coverage is undocumented.	Logical access weaknesses are identified. Verify privileged access, MFA, physical access and joiner/mover/leaver controls.
CC7 – System Operations	Monitor threats, manage security events and respond to incidents.	Inadequate alert review evidence; overdue incident response testing; backup restoration testing not evidenced.	Security monitoring and incident response need attention; restoration and other operational controls require verification.
CC8 – Change Management	Authorise, test and document system changes.	Change approvals and testing are not consistently supported by documentation.	Improve evidence of change approvals, testing, deployment and rollback procedures.
CC9 – Risk Mitigation	Manage risks arising from vendors and other dependencies.	Vendor risk assessments are incomplete.	Third-party risk management requires improvement; review vendor inventory, assessments, assurance reports and contracts.

5.1.2. Availability

Category / Criterion	Why It Is Relevant	Scenario Evidence	Finding or Limitation
Availability - A1: Availability	Assesses whether PayGo can meet agreed service availability and recovery commitments.	Backup restoration testing is not evidenced. The scenario provides limited information about continuity, disaster recovery and availability controls.	Recovery capability is not demonstrated by the available evidence. Confirm service commitments, recovery objectives, continuity arrangements and test results.
Availability - A1: Backup and Recovery	Assesses whether data and systems can be restored after disruption, failure or data loss.	The case study does not provide completed backup restoration-test evidence.	Restoration effectiveness remains unverified. Obtain backup logs, restoration-test results, integrity checks and remediation records.
Availability - A1: Resilience and Recovery Planning	Assesses whether PayGo can recover services and meet defined operational requirements after an incident.	Incident response testing is overdue and restoration testing is not evidenced; a complete business continuity or disaster recovery programme is not described.	Verify continuity and disaster recovery plans, RTOs, RPOs, recovery procedures and exercise results.
Availability - A1: Monitoring and Service Disruption	Assesses whether interruptions are detected, managed and measured against availability commitments.	Security alert-review evidence is inadequate, but the case study does not establish a weakness in service-availability monitoring.	Uptime monitoring, outage response, capacity planning and availability reporting require verification; security monitoring gaps alone do not prove availability-control failure.

Assessment note: These are preliminary SOC 2 readiness observations based on the case study. Missing evidence does not by itself establish that a control is absent or ineffective.

5.1.3. Confidentiality

The table assesses confidentiality-related safeguards against PayGo's case-study evidence. Identified weaknesses are distinguished from controls whose implementation or effectiveness remains unverified.

Category / Criterion	Why It Is Relevant	Scenario Evidence	Finding or Limitation
Confidentiality - C1: Confidential Information Protection	Protect confidential information in line with PayGo's commitments.	The case study involves customer and financial information, but provides limited detail about confidentiality-specific controls.	Confirm confidentiality commitments, relevant information classifications and the safeguards applied to protected information.
Confidentiality - C1: Access Restrictions	Limit access to confidential information to authorised users.	Permissions are not fully mapped to approved roles; reviews are missing for two systems; MFA coverage is undocumented.	Identified access weaknesses may expose confidential data. Verify affected systems, role permissions, access reviews and MFA controls.
Confidentiality - C1: Data Classification and Handling	Identify confidential information and define appropriate handling requirements.	A formal classification scheme and documented handling rules are not established by the scenario.	Verify classification standards, handling procedures, assigned responsibilities and evidence of implementation.

Confidentiality - C1: Protection Against Unauthorised Disclosure	Prevent unauthorised disclosure to internal or external parties.	Vendor risk assessments are incomplete and access weaknesses are identified; no actual disclosure is established.	Review third-party access, sharing arrangements, encryption and other safeguards. Record potential exposure without alleging a confirmed breach.
Confidentiality - C1: Retention and Disposal	Retain and securely dispose of confidential information in line with commitments.	The case study does not specify retention periods or evidence of secure deletion and disposal.	Verify retention schedules, deletion and disposal procedures, supporting records and vendor disposal arrangements.
Confidentiality - C1: Monitoring and Evidence	Demonstrate that confidentiality controls operate effectively.	Security alert-review evidence is inadequate and vendor risk assessments are incomplete.	Map confidentiality controls to supporting evidence, address monitoring gaps and test control operation.

5.1.4 Summary of selected categories

Category	Assessment Conclusion	Key Actions
Security	The foundational SOC 2 category and the clearest priority. The case study identifies weaknesses in access management, monitoring, incident response, change management and vendor oversight.	Strengthen role-based access and access reviews; verify MFA; improve alert reviews, incident response testing, change approvals and testing, risk assessment and vendor oversight.
Availability	Relevant where PayGo has availability or recovery commitments. The case study does not provide enough evidence to determine whether recovery and continuity controls operate effectively.	Confirm service commitments and recovery objectives; obtain backup restoration-test evidence; review business continuity and disaster recovery arrangements.
Confidentiality	Relevant where PayGo commits to protecting confidential information. Identified access and vendor weaknesses may affect confidentiality, but confidentiality-specific controls remain insufficiently evidenced.	Confirm information classification and handling requirements; validate access restrictions, third-party safeguards, retention, secure disposal and protection against unauthorised disclosure.

Assessment limitation: These findings represent a preliminary SOC 2 readiness assessment based on the PayGo case study. They do not constitute a formal SOC 2 attestation or confirmation that every referenced criterion has been breached.

5.2 SOC 2 Controls Assessment

This assessment evaluates PayGo's seven key control areas against the selected SOC 2 Trust Services Criteria. It identifies control weaknesses supported by the case study, areas requiring further evidence, associated risks and recommended corrective actions.

The assessment focuses on Security, Availability and Confidentiality, consistent with the proposed SOC 2 scope. Findings are preliminary and do not constitute a formal SOC 2 audit opinion.

CONTROL AREA	POLICY/CONTROL DECRIBED	SCENARIO EVIDENCE/LIMITATION	RISK	RECOMMENDED ACTION
Access Management	PayGo has an access management policy intended to govern access to systems and information.	Some system permissions are not mapped to approved job roles. Periodic access reviews are missing for the customer support system and central logging platform. These are confirmed control weaknesses. The scenario does not establish the effectiveness of other access management activities.	Excessive or inappropriate access privileges may remain undetected, increasing the risk of unauthorised access, misuse of information and disclosure of confidential data.	Map system permissions to approved roles, review existing user access against business requirements, and complete documented access reviews for customer support and central logging. Assign review responsibilities and track identified exceptions to resolution.
2. Multi-Factor Authentication (MFA)	MFA is an authentication safeguard relevant to protecting access to PayGo's systems. The scenario does not confirm its implementation or coverage across in-scope systems.	MFA coverage across PayGo's in-scope systems is not documented. This is an evidence gap, not confirmation that MFA is absent.	Accounts without appropriate authentication safeguards may be more vulnerable to credential compromise and unauthorised access.	Verify MFA implementation across in-scope systems, document system and account coverage, identify exceptions, and address any confirmed deficiencies. Retain configuration records and supporting evidence.
3. Security Monitoring	PayGo uses a central logging platform and maintains security monitoring records to support detection and review of security events.	Existing monitoring records do not establish that all critical security alerts are reviewed within defined timeframes. This is an evidence gap concerning timely alert review; the scenario does not establish that alerts were ignored.	Delayed identification or escalation of security events may increase the impact of incidents and expose PayGo's systems and information to prolonged threats.	Verify alert review procedures and expected response timeframes. Assign monitoring responsibilities, review critical alert handling, and retain timestamped records of investigations, escalation and resolution.
4. Incident Response	PayGo has an incident response policy and documented procedures for responding to security incidents.	Incident response procedures have not been tested within the past twelve months. This is a confirmed testing deficiency. The scenario does not establish that the procedures themselves are absent or ineffective.	Untested procedures may result in delayed incident detection, containment, escalation and recovery, potentially increasing operational disruption and security impact.	Conduct a documented incident response exercise, evaluate the effectiveness of existing procedures, record lessons learned and assign corrective actions. Establish a recurring testing schedule and retain exercise results.
5. Change Management	PayGo has a change management policy intended to govern	Change records do not consistently demonstrate that required approvals	Inadequately controlled changes may introduce	Review and strengthen change management

	modifications to its systems and infrastructure.	and testing occurred before deployment. This is a confirmed documentation and control assurance weakness.	vulnerabilities, system errors or service disruptions and make it difficult to demonstrate that changes were appropriately authorised and tested.	procedures, require documented approval and testing before deployment, and verify compliance through periodic reviews of change records. Document exceptions and corrective actions.
6. Backup and Recovery	PayGo has a backup and recovery policy intended to support restoration of systems and information following disruptions.	Evidence of backup restoration testing is not provided. This is an evidence gap; the scenario does not establish that restoration testing has never occurred or that backups are ineffective.	Unverified recovery capabilities may increase the risk of prolonged service disruption, unsuccessful restoration or loss of critical information following an incident.	Obtain and review existing restoration-test records. Where testing cannot be demonstrated, conduct documented restoration exercises, evaluate results against defined recovery objectives and address identified deficiencies.
7. Third-Party Risk Management	PayGo has a vendor management policy, a vendor register and signed agreements with providers supporting cloud infrastructure, payment processing, identity verification, customer support, payroll and email services.	Provider records do not consistently identify data protection roles, processing locations, applicable international transfer arrangements or recent security risk assessments. Risk assessments and ongoing monitoring are incomplete for some providers. These are confirmed documentation and oversight weaknesses.	Incomplete provider assessments and monitoring may leave security, confidentiality and operational risks unidentified or inadequately managed, potentially affecting PayGo's systems, information and service delivery.	Complete outstanding provider risk assessments, verify relevant contractual and security obligations, update provider records and establish documented periodic monitoring. Prioritise providers according to their potential impact on PayGo's operations and information.

5.2.1 Control Assessment Summary

The assessment identifies confirmed weaknesses in access management, incident response testing, change management documentation and third-party risk management. Further evidence is required to verify MFA coverage, timely security alert reviews and backup restoration effectiveness.

PayGo should prioritise remediation based on the potential impact of identified weaknesses on its security, availability and confidentiality commitments. Attention should be given to access governance, incident response preparedness, third-party oversight and recovery assurance.

The findings will inform the SOC 2 Evidence Register in Section 5.3 and the prioritised remediation plan in Section 6.

5.3 SOC 2 Evidence Register

Control area	Evidence required	Status	Purpose	Further information needed
1. Access Management	Access management policy; approved role-based access control matrix; current user account listings; access request and approval records; privileged account inventory; periodic access review reports; reviewer sign-offs; documented exceptions and remediation records.	Evidence gap identified	To verify that system access is granted according to approved business roles, that permissions are appropriately authorised, and that periodic reviews identify and address excessive or inappropriate access.	PayGo has an access management policy, but some system permissions are not mapped to approved roles. Access reviews are missing for the customer support system and central logging platform. The assessor should obtain current access listings, verify role assignments, review approval records and confirm that outstanding access reviews and related remediation have been completed.
2. Multi-Factor Authentication (MFA)	MFA configuration exports; identity provider settings; authentication policies; inventory of systems and accounts subject to MFA; privileged access settings; documented exceptions; authentication test results and relevant implementation records.	Evidence gap identified	To determine whether MFA is implemented across relevant systems and accounts, whether authentication requirements are consistently enforced, and whether exceptions are formally authorised and managed.	The case study does not document MFA coverage across PayGo's systems. The assessor should identify systems within the proposed SOC 2 boundary, verify which accounts and access methods are protected by MFA, examine configuration records and determine whether any exceptions exist. The absence of documentation does not establish that MFA has not been implemented.
3. Security Monitoring	Security monitoring procedures; central logging configurations; alert severity classifications; critical alert records; investigation tickets; review timestamps; escalation records; reviewer acknowledgements; and records of alert resolution	Evidence gap identified	To verify that security events are monitored, critical alerts are reviewed within defined timeframes, and potential threats are appropriately investigated, escalated and resolved.	PayGo maintains security monitoring records, but these do not establish that all critical alerts are reviewed within defined timeframes. The assessor should verify monitoring responsibilities, obtain the applicable alert review requirements and examine timestamped records demonstrating when critical alerts were generated, reviewed,

				investigated and resolved.
4. Incident Response	Incident response policy and procedures; incident classification and escalation guidance; incident register; exercise plans; tabletop or simulation test records; exercise attendance; testing results; lessons learned; corrective-action plans and remediation closure records.	Evidence gap identified	To determine whether PayGo's incident response arrangements are documented, understood by responsible personnel and periodically tested to evaluate preparedness, escalation procedures and response effectiveness	The case study confirms that incident response procedures exist but have not been tested within the past twelve months. The assessor should review the current procedures, obtain any historical exercise records and request evidence of updated testing, documented results, identified weaknesses and completed corrective actions. This finding does not establish that incident response procedures are absent.
5. Change Management	Change management policy; change request tickets; risk and impact assessments; documented management approvals; pre-deployment testing results; deployment records; emergency change documentation; rollback procedures; exception reports and post-implementation review records.	Evidence gap identified	To verify that changes to PayGo's systems are appropriately requested, assessed, authorised, tested and documented before implementation, reducing the risk of unauthorised changes, vulnerabilities and operational disruption.	PayGo has a change management policy, but change approval and testing records are inconsistent. The assessor should examine a sample of relevant changes, verify whether required approvals and testing occurred, identify documentation exceptions and confirm that corrective measures have been implemented. The scenario does not establish that every change was unauthorised or inadequately tested.
6. Backup and Recovery	Backup and recovery policy; backup schedules; system and data coverage records; backup job logs; failure notifications; backup retention and protection settings; recovery time objectives (RTOs); recovery point objectives (RPOs); restoration test plans; restoration results; data integrity checks and corrective-action records.	Evidence gap identified	To assess whether PayGo maintains appropriate backup arrangements and can demonstrate that critical systems and information are recoverable following an operational disruption, system failure or security incident.	The case study confirms the existence of a backup and recovery policy but does not provide evidence of restoration testing. The assessor should verify backup coverage, schedules and monitoring records; establish whether recovery objectives have been defined; and obtain documented restoration results. Where testing cannot be demonstrated,

				PayGo should conduct restoration exercises and record the outcomes.
7. Third-Party Risk Management	Vendor management policy; current vendor register; signed supplier agreements; provider risk assessments; risk ratings; security questionnaires; available independent assurance reports; contractual security and confidentiality requirements; processing location records; international transfer documentation; ongoing monitoring reports and remediation records.	Evidence gap identified	To verify that PayGo identifies, assesses and monitors risks associated with external service providers and that appropriate contractual and operational safeguards support the security, availability and confidentiality of its services and information.	PayGo maintains a vendor register and signed agreements with providers supporting cloud infrastructure, payment processing, identity verification, customer support, payroll and email. However, provider records are inconsistent regarding data protection responsibilities, processing locations and international transfer arrangements. Risk assessments and ongoing monitoring are incomplete for some providers. The assessor should identify affected providers, obtain outstanding assessments, verify relevant contractual safeguards and confirm ongoing monitoring arrangements.

.

6.0 PART C - INTEGRATED GAP ANALYSIS AND REMEDIATION PLAN

6.1 PayGo Financial Technologies Ltd. - GDPR and SOC 2 Remediation Plan

This section consolidates the material findings from PayGo Financial Technologies Ltd.'s GDPR Gap Assessment and SOC 2 Readiness Assessment. Each finding is evaluated against the applicable GDPR obligations and/or SOC 2 Trust Services Criteria, while recognising that compliance with one framework does not automatically establish conformity with the other.

The proposed corrective actions address confirmed weaknesses and outstanding evidence limitations. Where appropriate, shared remediation activities are identified to strengthen both data protection compliance and security assurance. Priorities reflect potential risk, business impact and the urgency of corrective action.

Finding / scenario evidence	GDPR obligations	Assessment status	Potential risks /	Corrective actions	Priority	Proposed responsible role	Evidence required for completion

	and/or SOC 2 criteria		**business impact**				
1. Incomplete privacy notice. The notice omits some recipient categories and applicable retention information.	**GDPR Arts. 5(1)(a), 12-14 -** Transparency: Require personal data processing to be transparent and individuals to receive clear information about processing, including relevant recipients and retention periods.	Confirmed gap	Inadequate transparency, complaints, regulatory scrutiny and reduced customer trust.	Update the privacy notice to accurately disclose recipient categories and retention periods. Verify its contents against PayGo's processing records.	High	Privacy Lead / Compliance	Approved revised notice, recipient inventory, disclosure checklist and publication record.
2. Incomplete RoPA. PayGo's records of processing activities are incomplete.	**GDPR Art. 30** - Records of Processing Activities: Requires applicable controllers and processors to maintain records of processing activities, including relevant purposes, data categories, recipients and retention information. Art. 5(2) - Accountability: Requires controllers to demonstrate compliance with data protection principles.	Confirmed gap	Limited visibility of processing activities and difficulty demonstrating accountability.	Complete and validate the RoPA across the seven identified processing activities, including purposes, categories, recipients, retention and relevant transfers.	High	Privacy Lead / Business Process Owners	Completed RoPA, supporting inventory, owner validation and approval records.
3. Retention and deletion weaknesses. PayGo has a retention schedule, but some periods lack documented justification	**GDPR Art. 5(1)(e) -** Storage Limitation: Requires personal data to be retained no longer than necessary for its purposes,	Confirmed gap; deletion effectiveness unverified	Unjustified retention, residual personal data and increased exposure to unauthorised access.	Document retention justifications, validate deletion procedures and conduct end-to-end deletion testing,	High	Privacy Lead / IT Operations	Approved retention rationale, deletion procedures, test logs, provider confirmations and corrective-

and deletion has not been tested across all systems and providers.	subject to applicable exceptions. Art. 5(2) - Accountability: Requires demonstration of compliance. **SOC 2 C1 -** Confidentiality : Addresses the protection and appropriate disposal of information designated confidential, where applicable.			including relevant providers.			action records.
4. Access management deficiencies. Some permissions are not mapped to approved roles; completed reviews are missing for the customer support system and central logging platform.	**GDPR Art. 32** - Security of Processing: Requires appropriate technical and organisational security measures based on processing risks. **SOC 2 CC6 –** Logical and Physical Access Controls: Addresses restricting access to systems and information to authorised users through appropriate access controls.	Confirmed gap; control effectiveness not fully verified	Excessive or outdated privileges, unauthorised access and possible disclosure of sensitive information	Establish approved role-permission mappings, apply least privilege, complete access reviews for both systems and remediate exceptions.	High	IT Security / System Owner	Approved role matrix, access listings, completed review reports, sign-offs and remediation tickets.
5. MFA coverage undocumented . The scenario does not establish MFA coverage across in-scope systems.	**GDPR Art. 32** - Security of Processing: Requires security measures appropriate to the risks, which may include strong authentication safeguards. **SOC 2 CC6 -** Logical and Physical	Evidence gap	Potential credential compromise and unauthorised access where authentication safeguards are insufficient.	Inventory in-scope systems and accounts, verify MFA configurations, assess exceptions and address confirmed deficiencies	High	IT Security / IAM Lead	MFA coverage matrix, configuration exports, test results and approved exception records.

	Access Controls: Addresses authentication and access restrictions intended to prevent unauthorised access.						
6. Security alert review evidence insufficient. Monitoring records do not establish that all critical alerts are reviewed within defined timeframes.	**GDPR Art. 32** - Security of Processing: Requires appropriate measures to maintain the security of personal data processing. **SOC 2 CC7 -** System Operations: Addresses detecting, monitoring, evaluating and responding to security events and incidents	Evidence gap	Delayed threat detection, escalation and incident containment.	Verify alert-review timelines, assign monitoring responsibilities, document investigations and track unresolved alerts.	High	Security Operations Lead	Alert logs, review timestamps, investigation tickets, escalation records and monitoring reports.
7. Incident response testing not performed within the past 12 months. PayGo has incident response procedures, but recent testing is absent.	**GDPR Art. 32** - Security of Processing: Includes regular testing and evaluation of security measures where appropriate. Arts. 33-34 - Personal Data Breach Notification: Establish notification requirements for qualifying personal data breaches. **SOC 2 CC7 -** System Operations: Addresses identifying, evaluating and responding to	Confirmed testing weakness; breach-notification arrangements unverified	Ineffective incident handling, delayed containment and possible failure to meet notification obligations.	Conduct a documented tabletop exercise, test escalation and breach-notification decisions, record lessons learned and address weaknesse	High	Incident Response Lead / Privacy Lead	Exercise plan, attendance, results, breach-decision workflow, corrective-action tracker and closure records.

	security incidents.						
8. Backup restoration testing not evidenced. A backup and recovery policy exists, but restoration effectiveness cannot be verified.	**GDPR Art. 32(1)(c)-(d)** - Recovery and Security Testing: Addresses restoring access to personal data following incidents and regularly testing security measures. **SOC 2 A1 -** Availability: Addresses controls supporting system availability, recovery and applicable service commitments.	Evidence gap	Prolonged outages, potential data loss and inability to meet recovery objectives.	Obtain existing restoration evidence or perform documented restoration tests, assess recovery objectives and remediate deficiencies.	High	IT Operations / Recovery Lead	Backup logs, restoration test results, integrity checks, recovery objectives and remediation records.
9. Change management records incomplete. Records inconsistently demonstrate approvals and testing before deployment.	**GDPR Art. 32** - Security of Processing: Requires appropriate safeguards, including managing security risks associated with system changes. **SOC 2 CC8 -** Change Management: Addresses authorising, designing, developing, testing, approving and implementing changes to infrastructure, data, software and procedures.	Confirmed documentation weakness; operating effectiveness unverified	Unauthorised or inadequately tested changes, vulnerabilities and service disruption.	Standardise pre-deployment approval and testing requirements, review change records and address documentation or control deficiencies.	Medium	IT Change Manager / Application Owners	Approved change tickets, testing results, deployment records, exception logs and review sign-offs.
10. Third-party governance deficiencies. Provider records inconsistently	**GDPR Art. 28** - Processor Requirements: Addresses the selection, contractual	Confirmed documentation and oversight gaps; transfer	Third-party security incidents, unclear contractual responsibilities	Complete provider risk assessments, verify contractual obligations	High	Vendor Risk Manager / Privacy Lead	Updated vendor register, completed assessments, reviewed

identify data protection roles, processing locations and transfer arrangements; some security assessments and monitoring are incomplete.	obligations and oversight of processors. Arts. 44-49 - International Transfers: Establish requirements for transfers of personal data to third countries or international organisations, where applicable. **SOC 2 CC9 -** Risk Mitigation: Addresses identifying and mitigating risks, including risks arising from vendors and business partners. C1 - Confidentiality : Addresses protecting confidential information, where relevant.	compliance unverified	, possible unlawful transfers and service disruption.	and processing locations, assess applicable transfer safeguards and establish ongoing monitoring.			agreements, relevant transfer documentation and monitoring records.
11. Lawful bases and other GDPR operational requirements cannot be fully verified. The scenario does not provide sufficient evidence of lawful bases, rights-request handling, accuracy controls or the full breach-notification workflow.	**GDPR Art. 6** - Lawfulness of Processing: Requires an appropriate lawful basis for processing personal data. **Art. 5(1)(d**) - Accuracy: Requires personal data to be accurate and updated where necessary. **Arts. 12 and 15-22** - Data Subject Rights: Establish transparency and rights relating to personal data. **Arts. 33-34 -**	Evidence gap	Potential deficiencies in lawful processing, inaccurate records, delayed rights responses or breach notifications.	Verify lawful bases for each processing purpose, assess accuracy and rights-request procedures, and confirm breach-notification decision processes.	Mediu m	Privacy Lead / Legal Counsel	Lawful-basis register, accuracy procedures, rights-request records, breach procedures and verification results

	Breach Notification: Address notification obligations following qualifying personal data breaches.						
12. Availability and confidentiality assurance evidence incomplete. Specific availability commitments, recovery objectives and confidentiality safeguards are not fully described.	**SOC 2 A1 -** Availability: Addresses controls supporting system availability in accordance with applicable commitments and requirements. **SOC 2 C1** - Confidentiality : Addresses identifying and protecting information designated confidential throughout its relevant lifecycle.	Evidence gap	Inability to demonstrate that relevant service commitments and confidentiality requirements are supported by effective controls.	Identify applicable service and confidentiality commitments, assess supporting controls and obtain evidence of their design and operation.	Mediu m	IT Operations / Information Security	Service commitments, availability reports, recovery objectives, classification records and control-testing evidence.
13. SOC 2 evidence mapping not established. PayGo has not established a central evidence register linking controls to applicable criteria and has not undergone a prior SOC 2 examination.	**SOC 2 CC4 -** Monitoring Activities: Addresses evaluating whether internal controls are present and functioning and communicatin g identified deficiencies. CC5 - Control Activities: Addresses selecting and developing control activities that mitigate risks. A central evidence register is a recommended readiness mechanism	Confirmed evidence-management gap	Fragmented assurance evidence, delayed readiness activities and inability to substantiate control operation	Establish a central evidence register, map controls to selected criteria, assign evidence owners and implement periodic evidence reviews.	Mediu m	GRC Lead / Compliance Manager	Approved evidence register, control-to-criteria mapping, evidence ownership records and review sign-offs.

	for demonstrating these controls, rather than an explicit standalone requirement of CC4 or CC5.						

6.2 Recommended implementation sequence

The following implementation sequence provides a proposed timeline for addressing the identified gaps and evidence limitations. The targets are indicative and should be adjusted based on PayGo's available resources, risk exposure and operational requirements.

Phase	Main activities	Suggested target
Phase 1 - Immediate risk reduction and privacy compliance	Complete missing access reviews for customer support and central logging; begin role-permission mapping; verify MFA coverage; strengthen critical-alert review; schedule incident response and restoration testing. Initiate corrections to the privacy notice, RoPA and retention justifications.	First 30 days
Phase 2 - Control remediation and governance	Complete incident response and restoration exercises; address identified control weaknesses; standardise change approval and testing records; document lawful bases and verify rights-request and breach-notification procedures. Establish a remediation tracker with responsible owners and completion evidence.	Days 31-60
Phase 3 - Third-party compliance and data lifecycle controls	Complete outstanding vendor assessments; verify processor responsibilities, processing locations and applicable international transfer safeguards; conduct deletion testing across relevant systems and providers; implement ongoing vendor monitoring.	Days 31-90
Phase 4 - Evidence consolidation and readiness validation	Establish the SOC 2 evidence register; map supporting evidence to selected Security, Availability and Confidentiality criteria; verify corrective-action closure; confirm the proposed SOC 2 examination type and reporting period; conduct a follow-up readiness assessment.	Days 61-90 and ongoing

The proposed timelines are planning targets and not deadlines specified in the case study. High-priority risks should be addressed as early as practicable, while applicable statutory deadlines must be assessed separately.

6.3 Remediation Completion and Governance Criteria

A remediation finding should only be marked as closed when sufficient evidence demonstrates that the identified weakness or evidence gap has been appropriately addressed.

Closure should require:

1. The corrective action has been implemented.
2. Supporting evidence has been collected and reviewed.
3. The relevant control has been tested, where applicable.
4. The designated control owner or reviewer has approved the outcome.
5. Any remaining risks, exceptions or limitations have been documented and appropriately approved.

These criteria promote accountability and ensure that remediation is assessed based on implementation and supporting evidence rather than policy documentation alone.

7.0 Conclusion

The GDPR Gap Assessment and SOC 2 Readiness Assessment of PayGo Financial Technologies Ltd. provided a structured evaluation of the organisation's data protection practices, information security controls and compliance readiness. The project examined the available case-study evidence, identified confirmed weaknesses and areas requiring further verification, and developed supporting deliverables, including a GDPR data inventory, preliminary data-flow analysis, gap assessments, evidence register and integrated remediation plan.

The findings indicate that PayGo has established policies and procedures covering several important operational and security functions. However, gaps in privacy notices, records of processing activities, retention documentation, access governance, incident response testing, change management records and third-party oversight require corrective action. In addition, insufficient evidence of MFA coverage, timely security alert reviews, effective deletion across relevant systems and providers, and successful backup restoration testing limits the organisation's ability to demonstrate control effectiveness. These findings highlight the importance of distinguishing confirmed deficiencies from evidence limitations rather than assuming that undocumented controls are absent.

From a GDPR perspective, PayGo should prioritise improvements to privacy transparency, processing records, retention and deletion practices, and third-party accountability. Further verification is required for lawful bases, data subject rights procedures, breach notification arrangements and international data transfers where applicable. For SOC 2 readiness, the

organisation should strengthen the design, implementation and supporting evidence of controls relevant to the proposed Security, Availability and Confidentiality Trust Services Categories. PayGo should also confirm its intended examination scope and whether a Type I or Type II report is appropriate, recognising that a Type II examination requires evidence of control operating effectiveness over a defined period.

The integrated remediation plan establishes a risk-based approach to addressing the identified weaknesses through prioritised corrective actions, proposed responsible roles, implementation targets and evidence-based closure criteria. Successful implementation will require management oversight, clear accountability, periodic control testing and coordinated involvement across relevant business and technical functions. Regular access reviews, vendor assessments, incident response exercises, recovery testing and evidence maintenance will also be important for sustaining improvements beyond the initial assessment.

Ultimately, the project provides PayGo with a practical foundation for strengthening information security, privacy governance and operational resilience. However, GDPR compliance and SOC 2 readiness are distinct, and the available evidence does not support a definitive conclusion that PayGo is fully GDPR compliant or ready for a successful SOC 2 examination. A readiness assessment does not itself establish GDPR compliance or constitute a SOC 2 attestation. PayGo's next steps should therefore focus on validating the findings, implementing the recommended corrective actions and verifying their effectiveness through appropriate documentation, review and testing. The long-term value of this assessment will depend on the organisation's ability to translate its findings into effective, consistently monitored controls that protect personal information and strengthen stakeholder confidence.